

10 Security+ PBQ Walkthroughs

The CIA Triad applied to performance-based questions — with the reasoning CompTIA grades on.

By Dave, founder of [CipherExam](#)

Why this sheet exists

You can pass every Security+ practice quiz at 90% and still walk out of the testing center shaken. The reason isn't a knowledge gap. It's that **PBQs (Performance-Based Questions) test whether you can operate, not whether you can recognize.**

Flashcards drill facts. PBQs drill judgment. Three or four PBQs at the start of the exam can sink the rest of your score before you've answered a single MCQ.

This sheet gives you:

1. **The CIA Triad lens** — the single question CompTIA grades against
2. **10 worked PBQ scenarios** covering drag-drop, topology, and CLI-emulation formats
3. **The 3 PBQ traps** CompTIA plants in nearly every performance item

If you internalize the lens, the PBQs stop feeling like trick questions.

The Lens, in one sentence

CIA triad — which principle is being protected?

That's it.

Every Security+ scenario is testing one of three principles:

- **Confidentiality** — keeping the right eyes off the data
- **Integrity** — keeping the data unaltered or detecting alteration
- **Availability** — keeping the system reachable when needed

Before you read the options on any PBQ, name the principle. The control that protects *that* principle is the right answer. The wrong answers usually protect a *different* principle correctly — which is why they feel plausible.

That last sentence is the most important one in this sheet. Read it twice. **Wrong PBQ answers are almost always controls that protect the wrong principle.**

The 3 PBQ trap types

After the lens, the second-biggest unlock is recognizing how CompTIA constructs wrong answers:

Trap 1 — Right control, wrong principle

The option is a real, well-known security control — but it protects a different CIA principle than the scenario actually tests. Example: choosing TLS (a confidentiality-leaning control) when the scenario is testing integrity (an HMAC or digital signature is the right answer).

Trap 2 — Newer control over correct control

The option introduces a buzzword-shiny technology (zero trust, SASE, EDR) when the scenario is asking about a fundamental control. Newer isn't wrong, but it often isn't *what's being tested*. Check whether the older, simpler control would also solve the stated problem — usually that's the right answer.

Trap 3 — Over-scoped response

The option fixes the symptom by deploying a multi-million-dollar enterprise platform when the question gives you one workstation. Scope-match the answer to the situation. If the scenario describes a small office, the answer probably isn't "deploy a SIEM cluster."

Scenario 1 — Drag-drop: pair the control to the threat

Setup: You're given six security controls and six threats. Drag each control to the threat it most directly mitigates.

Threats: SQL injection, sniffed credentials over Wi-Fi, ransomware encrypting backups, expired TLS certificate, USB drop in the parking lot, account takeover from a leaked password

Controls: Parameterized queries, WPA3, immutable/offline backups, certificate auto-renewal, USB device control policy + tamper-evident labels, MFA on all accounts

Applying the lens (one pairing at a time):

Threat	Principle attacked	Right control	Why
SQL injection	Integrity (and Confidentiality)	Parameterized queries	Input validation at the boundary — addresses the cause, not the symptom
Sniffed credentials over Wi-Fi	Confidentiality	WPA3	Modern over-the-air encryption
Ransomware encrypting backups	Availability (and Integrity of the backup)	Immutable/offline backups	The whole point of offline = ransomware can't reach it
Expired TLS certificate	Availability (users locked out)	Certificate auto-renewal	Prevents recurrence, not the symptom
USB drop in parking lot	Multiple — but Integrity/Confidentiality risk is highest	USB device control policy	Removes the attack vector entirely
Account takeover from leaked password	Confidentiality (and Integrity)	MFA on all accounts	Defeats password-only auth

Top wrong-answer trap on this kind of drag-drop: matching SQL injection to "Web Application Firewall." A WAF *helps* but parameterized queries *fix*. CompTIA grades for the root-cause fix, not the perimeter mitigation.

Scenario 2 — Topology: where do you put the IDS?

Setup: A network diagram shows: Internet → Edge Router → Firewall → Switch → 3 zones: DMZ (web servers), Internal LAN (workstations), Database Subnet. You're asked to drag IDS sensors onto the topology to detect malicious activity reaching the internal network.

Applying the lens: This is asking what *visibility* (an Integrity/Detection control) gets you the most signal at the lowest cost.

The right placements:

1. **Between the firewall and the switch** — catches anything that made it past the firewall
2. **On the internal LAN switch span port** — catches lateral movement between workstations

3. On the database subnet — catches direct attacks on the data tier

The trap: placing IDS at the edge router (outside the firewall). The internet is constantly noisy; an IDS there generates so much alert volume that the real signals drown. CompTIA grades for *useful* placements, not maximum coverage.

Bonus: placing IDS in the DMZ is debatable. If the question specifically mentions PCI or compliance, yes. Otherwise the firewall logs cover the DMZ adequately.

Scenario 3 — CLI emulation: triage a suspected compromise

Setup: A terminal opens. You're told a user reported strange behavior on their workstation. Triage the host in this order: (1) confirm the user, (2) list logged-in sessions, (3) identify suspicious processes, (4) check recent network connections.

The right commands (Linux example — Windows variants exist):

```
whoami                # confirm your identity
who                   # who is currently logged in
ps -ef | grep -v root # processes not owned by root
netstat -anp | grep ESTABLISHED # active connections with PIDs
ss -tnp               # modern netstat alternative
last -a               # recent login history
```

Applying the lens: This is testing whether you can preserve **Integrity of the investigation**. The order matters — you confirm scope before taking action.

The trap: running `systemctl stop suspicious-service` or `kill -9 <pid>` before you've documented the state. CompTIA grades for evidence preservation. Acting before documenting destroys evidence.

Scenario 4 — Drag-drop: classify the malware

Setup: Six malware behaviors. Classify each as virus, worm, trojan, ransomware, rootkit, or spyware.

Behaviors: - Replicates by attaching to executable files - Spreads autonomously across a network with no user action - Disguises itself as a legitimate utility a user installs - Encrypts user files and demands payment - Hides at the kernel level to maintain persistence - Logs keystrokes and screenshots silently

The mappings:

Behavior	Type	What CIA principle it attacks
Replicates via executable files	Virus	Integrity (the host binary)
Autonomous network spread	Worm	Availability (network resources)
Disguised legitimate utility	Trojan	Integrity (user trust)
Encrypts files for ransom	Ransomware	Availability (data)
Kernel-level persistence	Rootkit	Integrity (the OS itself)
Silent key/screen logging	Spyware	Confidentiality

Applying the lens: the principle-attacked column is what CompTIA *really* grades. The malware-type label is just a name. If you know which principle is broken, the right defense follows.

The trap: confusing virus with worm. The clean line: viruses need a host file and (usually) user action; worms self-propagate. If the scenario says "spread without user interaction," it's a worm.

Scenario 5 — CLI emulation: configure a firewall rule

Setup: You have a small office firewall. A web server (10.0.1.50) needs to accept HTTPS from the internet. Configure the minimum-necessary rules.

The minimum rules (iptables-style example):

```
# Allow inbound HTTPS to the web server
iptables -A FORWARD -p tcp --dport 443 -d 10.0.1.50 -j ACCEPT

# Allow related/established traffic (return packets)
iptables -A FORWARD -m state --state RELATED,ESTABLISHED -j ACCEPT

# Drop everything else
iptables -A FORWARD -j DROP
```

Applying the lens: This is testing the principle of **least privilege** — a Confidentiality/Integrity protection.

The trap: adding rules that open more ports "just in case" — opening 80, 22, and 3306 to the web server because "the web server uses those internally." CompTIA grades for *necessary* rules only. If the scenario doesn't mention SSH or MySQL needing external access, don't open them.

Scenario 6 — Drag-drop: incident response phase

Setup: Six actions during an incident. Place each in the correct IR phase: Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned.

Actions: - Run a tabletop exercise quarterly - Discover unusual outbound traffic on a workstation - Disable the user's account and isolate the host from the network - Reimage the host from a known-good baseline - Restore data from the most recent verified-clean backup - Update the runbook based on what went wrong

Action	Phase	Why
Tabletop exercise quarterly	Preparation	Pre-incident, builds muscle memory
Discover unusual outbound traffic	Identification	Recognition of "this is real"
Disable account + isolate host	Containment	Stop the bleeding, don't fix yet
Reimage from baseline	Eradication	Remove the cause
Restore from verified-clean backup	Recovery	Return to operations
Update runbook	Lessons Learned	Close the loop

The trap: confusing Containment with Eradication. Containment is "stop it from spreading"; Eradication is "remove the cause from the system." Both involve action — the test is whether you can name the *intent*.

Scenario 7 — Topology: VLAN segmentation for a small clinic

Setup: A small clinic has: 5 admin workstations, 10 clinical workstations accessing patient records, 3 medical IoT devices, 1 guest Wi-Fi network. Segment the network to minimize PHI exposure.

The right segmentation:

VLAN	Devices	Rule
VLAN 10 — Admin	5 admin workstations	Can reach internet; cannot reach Clinical VLAN
VLAN 20 — Clinical	10 clinical workstations	Can reach EHR + internet; cannot reach IoT or Guest
VLAN 30 — Medical IoT	3 medical devices	Can reach only required management endpoints; no internet
VLAN 40 — Guest	Wi-Fi clients	Internet only; cannot reach any internal VLAN

Applying the lens: This is a **Confidentiality** problem (PHI) crossed with an **Availability** problem (medical IoT must not be DDoSed by guest traffic).

The trap: flattening everything into "internal vs. external." Modern Security+ exams test multi-VLAN segmentation explicitly. If the scenario gives you four distinct device types, the answer probably involves four (or more) VLANs.

Scenario 8 — CLI emulation: log analysis

***Setup:** You're given a snippet of access logs and asked to identify suspicious patterns.*

```
2026-05-28 03:14:22 GET /login.php - 200 - 192.168.1.100
2026-05-28 03:14:24 POST /login.php - 401 - 192.168.1.100
2026-05-28 03:14:25 POST /login.php - 401 - 192.168.1.100
2026-05-28 03:14:26 POST /login.php - 401 - 192.168.1.100
2026-05-28 03:14:27 POST /login.php - 401 - 192.168.1.100
[continues for 4,000 entries from the same IP]
2026-05-28 03:18:11 POST /login.php - 200 - 192.168.1.100
2026-05-28 03:18:12 GET /admin/users.php - 200 - 192.168.1.100
```

The pattern: brute-force followed by successful login. Then immediate access to `/admin/users.php`.

Applying the lens: **Confidentiality** breach (account compromise) and the start of a **Privilege Escalation** path.

The right action: Lock the account, force a password reset, audit `/admin/users.php` for changes during the active session window, and check for any new admin accounts created from that IP.

The trap: the question may offer "block 192.168.1.100." That's helpful but insufficient — the attacker is already in. Containment requires both blocking the IP *and* invalidating the session.

Scenario 9 — Drag-drop: cryptographic primitives

Setup: Match each cryptographic need to the right primitive.

Needs: Verify a downloaded file is unaltered · Encrypt data at rest · Secure web traffic · Verify a digital signature · Hash passwords for storage · Exchange a session key over an untrusted channel

Primitives: SHA-256, AES-256, TLS 1.3, RSA/ECDSA, Argon2 / bcrypt, Diffie-Hellman / ECDH

Need	Right primitive	CIA principle
Verify file unaltered	SHA-256	Integrity
Encrypt data at rest	AES-256	Confidentiality
Secure web traffic	TLS 1.3	Confidentiality + Integrity (in transit)
Verify a digital signature	RSA/ECDSA	Integrity + Authentication
Hash passwords for storage	Argon2 / bcrypt	Confidentiality (stored credentials)
Exchange session key	Diffie-Hellman / ECDH	Confidentiality

The trap: using SHA-256 for password storage. SHA is *fast* — designed for it. Password hashing should be *slow* (Argon2, bcrypt). Speed is a feature for one and an attack vector for the other.

Bonus trap: using AES for hashing or SHA for encryption. Encryption is reversible (with a key). Hashing is one-way. Mixing them on the exam is automatic-wrong.

Scenario 10 — Topology + CLI: zero-trust verification

Setup: A user on the marketing team needs to access a financial reporting dashboard. The company is moving to zero-trust. Describe the verification flow.

The right flow:

1. **Identity verification** — user authenticates (SSO + MFA)
2. **Device posture check** — endpoint compliance (patched, encrypted, EDR running)
3. **Context evaluation** — time of day, geolocation, network reputation
4. **Authorization** — does this user-role need access to *this* dashboard?

5. **Continuous re-verification** — re-evaluate on session refresh, not just at login

Applying the lens: Zero trust protects **Confidentiality** (data) by replacing "are you on the network?" with "are you, with this device, in this context, authorized for *this* resource right now?"

The trap: assuming zero trust = VPN. It's the opposite. VPN says "if you're inside the perimeter, you're trusted." Zero trust says "the perimeter doesn't exist; verify every request." Picking the VPN answer on a zero-trust question is automatic-wrong.

Your next move

You now have:

1. **The Lens.** Before reading any option, name the CIA principle being protected.
2. **The 3 PBQ traps.** Right-control-wrong-principle, newer-over-correct, over-scoped.
3. **10 worked PBQ scenarios** across drag-drop, topology, and CLI formats.

Reading this sheet is step one. **Building the reflex is step two**, and that takes reps on PBQ-format items specifically — not just MCQs.

That's what CipherExam is built for.

Every Security+ question in CipherExam: - Supports the real PBQ formats (drag-drop, matching, network topology) — not just text approximations - Comes with a CIA Triad Lens walkthrough on every answer (right and wrong) - Surfaces your personal "thinking traps" — where you keep falling into Trap 1, 2, or 3 - Builds toward a 90-question Full Mock with PBQ support — same length and pacing as SY0-701

Start your 7-day free trial. No credit card.

→ cipherexam.com/lp/security-plus

The PBQs stop feeling like trick questions.

— Dave, founder of CipherExam